MODULE 17 · DOMAIN 3 - APPLICATION DEVELOPMENT

Guardrails in the application

Layers of protection on the way in and the way out, and how Databricks lets you configure them without code.

SECTION 3 of 6 EXAM WEIGHT 30% MODULE 17 of 40

admin@sthithapragna.com

A guardrail is a bouncer. One at the door checks who and what comes in. One at the exit checks what goes out.

A system prompt rule, or a guardrail?

SYSTEM PROMPT RULE

Asks the model to behave

- Cheap and quick to add
- Shapes normal behaviour
- Can be argued around by users
- No record of what it stopped

GUARDRAIL

Checks independently

- A separate check on input or output
- Works even if the model is tricked
- Can block, redact or log
- Violations can be recorded

THE TIEBREAKER

When a scenario says the system prompt sometimes fails, or the rule is a compliance requirement, the answer is an enforced guardrail.

Layers from request to response

01
Input
Jailbreaks, unsafe content, PII, off-topic.

02
Retrieval
Only documents this user may see.

03
Tools
Least privilege, approval for actions.

04
Output
Unsafe content, PII, hallucination, format.

05
Record
Log violations for review.

ON THE EXAM

No single layer catches everything. Defence in depth means each layer covers the gaps in the others.

Unity AI Gateway guardrail types

TYPE	ACTION	PHASE
PII redaction	Replace with placeholders such as [NAME]	Input or output
PII blocking	Block the request or response	Input or output
Unsafe content	Block hate, violence, self-harm and more	Input or output
Jailbreak	Block attempts to bypass safety rules	Input only
Hallucination	Block fabricated or unverifiable claims	Output
Custom	Your prompt: block or sanitise	Input or output

ON THE EXAM

Jailbreak runs on input only. Hallucination runs on output. The others can run on either side.

A prompt plus an evaluator model

- Each guardrail is an **editable prompt** run by an **evaluator endpoint**, such as a small hosted model.
- **Enforce** mode blocks or sanitises. **Log** mode only records, as a dry run.
- Databricks advises **one guardrail per policy**, so each can be tuned or disabled alone.
- End users need only **CAN QUERY** on the gateway endpoint, not on the evaluator.
- The configuration screens are still evolving. Learn the types and behaviour, not the clicks.

> ON THE EXAM
>
> A guardrail is itself a model call. It adds latency and cost, which is another reason to scope it to one clear policy.

Block, or redact?

BLOCK

Stop the request or response

- Nothing reaches the model or user
- Safest for clearly forbidden content
- Can stop legitimate work
- Right for jailbreaks and unsafe content

REDACT, OR SANITISE

Clean it and carry on

- Sensitive parts replaced
- The request still completes
- Keeps the application useful
- Right when data is needed less than the task

THE TIEBREAKER

If the task must still work but certain data must not travel, redact. If the content itself is forbidden, block.

Guardrails you can build into the application

- A **topic classifier** on input, refusing requests outside the application's scope.
- A **safety classifier model**, such as Llama Guard, scoring input and output.
- **Schema validation** of structured output before a program uses it.
- **Rule checks**, such as regular expressions for card numbers.
- A **safe fallback** reply when a guardrail fires, rather than an error.

> ON THE EXAM
>
> Whatever blocks the response, the user should get a clear, polite fallback, not a silent failure.

How to introduce a new guardrail safely

01
Write
One policy, clear rules, a few examples.

02
Log mode
Run as a dry run on real traffic.

03
Review
False positives and misses in the inference table.

04
Refine
Adjust the prompt and examples.

05
Enforce
Switch on when errors are acceptable.

ON THE EXAM

Log mode first. A guardrail that blocks good customers is its own kind of outage.

Harbourline's guardrails

01
Door
Jailbreak block, PII redaction before the model.

02
Scope
Topic classifier: insurance questions only.

03
Data
Retrieval filtered to the customer's own policy.

04
Exit
Unsafe content and hallucination checks.

05
Fallback
Polite refusal, with a phone number.

ON THE EXAM

The two injection cases from module 16 are now stopped at the door, and would be caught at the exit if they got through.

> A bank's assistant must never give opinions on political topics. Its system prompt says so, but testers can still coax political opinions out of it.
>
> Compliance says the rule must be reliably enforced.

What should the engineer add?

A Raise the temperature so responses vary more widely

B An input guardrail that detects the topic and returns a refusal

C Retrieval of more banking documents for every request

D A larger model that follows system prompts more closely

◆ PAUSE AND DECIDE

What should the engineer add?

A Higher temperature

More variety, and more chance of a political answer.

B Input topic guardrail

An independent check that refuses before the model answers.

C More banking documents

Adds context. Does not stop a political question.

D Larger, more obedient model

Still relies on the prompt, which testers already beat.

THE SIGNAL

The system prompt sometimes fails, and compliance needs enforcement. Both signals point to a guardrail.

A support assistant sends each request to an externally hosted model through Unity AI Gateway. Requests often contain customer names and email addresses.

Policy says raw personal data must never reach the external provider, but the assistant must keep answering.

Which guardrail meets the requirement?

A PII blocking on input, rejecting any request with personal data

B A system prompt instructing the model not to store personal data

C PII redaction on output, masking personal data in the replies

D PII redaction on input, replacing personal data before the model call

◆ PAUSE AND DECIDE

Which guardrail meets the requirement?

A PII blocking on input

Protects the data, but most requests would fail.

B System prompt

The data has already reached the provider by then.

C PII redaction on output

Wrong side. The data already went out in the request.

D PII redaction on input

Data is masked before it travels, and requests still complete.

THE SIGNAL

Must never reach the provider, but must keep answering. Before the call means input; keep answering means redact, not block.

> Users are trying to bypass an assistant's rules with role-play framings and instructions encoded in Base64.
>
> The team wants these attempts stopped with a Unity AI Gateway guardrail.

Which configuration fits?

A. A jailbreak guardrail on the input phase

B. A hallucination guardrail on the output phase

C. A PII redaction guardrail on the output phase

D. A jailbreak guardrail on the output phase

◆ PAUSE AND DECIDE

Which configuration fits?

A Jailbreak, input

Built for overrides, role-play and encoded payloads, on input.

B Hallucination, output

Checks invented claims, not bypass attempts.

C PII redaction, output

Masks personal data. Nothing to do with bypassing rules.

D Jailbreak, output

Right type, wrong phase. Jailbreak runs on input only.

THE SIGNAL

Role-play and encoded instructions are jailbreak techniques, and the jailbreak guardrail runs on input only.

> A retailer writes a custom guardrail to stop replies that recommend competitors' products. It worries the guardrail might block ordinary replies by mistake.
>
> The assistant serves thousands of customers a day.

How should the team introduce it?

A Enforce it for all users at once, and fix problems as they appear

B Skip the guardrail and rely on a system prompt instruction instead

C Run it in Log mode first, and review results in the inference table

D Replace the evaluator with the largest model available straight away

◆ PAUSE AND DECIDE

How should the team introduce it?

A Enforce for all at once

Mistaken blocks would hit thousands of customers.

B System prompt only

Loses enforcement, which was the reason for the guardrail.

C Log mode, then review

Measures false positives safely before anything is blocked.

D Largest evaluator first

Adds cost and latency before knowing there is a problem.

THE SIGNAL

Worried about blocking ordinary replies. Log mode is a dry run: it shows the mistakes without making any.

What to carry forward

- A system prompt asks. A **guardrail enforces**. Compliance rules need guardrails.
- Layers: **input, retrieval, tools, output**, with violations recorded.
- Gateway types: PII redaction and blocking, unsafe content, **jailbreak on input**, **hallucination on output**, custom.
- Redact when the task must continue. Block when the content is forbidden.
- New guardrail: **Log mode first**, review, then enforce.

> ON THE EXAM
>
> Next: module 18 builds agents with MLflow and Custom Agents, including tracing and Unity Catalog tools.